

Tor: Onion Routing e Anonimato Bidirezionale

NECKER

18 Novembre 2025

Indice

1	Introduzione al Tor (The Onion Router)	2
1.1	Principi del Routing a Cipolla	2
2	Confronto sui Livelli di Sicurezza, Privacy e Anonimato	3
2.1	1. Connessioni Senza Crittografia (HTTP Normale)	3
2.2	2. Connessioni Crittografate (HTTPS Normale)	3
2.3	3. Anonimato con Traffico Non Cifrato (TOR senza HTTPS)	3
2.4	4. Anonimato e Crittografia (TOR con HTTPS)	4
3	Creazione di un Circuito Tor	5
3.1	Fasi di Creazione	5
3.2	Fase di Comunicazione	5
4	Anonimato Bidirezionale: I Servizi Nascosti	6
4.1	Struttura e Ruoli dei Nodi Specializzati	6
4.2	Processo di Stabilimento della Connessione	6
4.3	Processo di Stabilimento della Connessione Onion Service	6
4.4	Rendezvous: L'Incontro Finale	7
5	Limiti e Svantaggi di Tor	8

1 Introduzione al Tor (The Onion Router)

Tor è un sistema che mira a garantire l'anonimato nella comunicazione Internet instradando il traffico attraverso una rete globale volontaria di relay (nodi). L'anonimato è raggiunto attraverso la tecnica del **Routing a Cipolla** (*Onion Routing*).

1.1 Principi del Routing a Cipolla

L'informazione viene incapsulata in strati successivi di crittografia, come gli strati di una cipolla. Ogni relay (nodo) sul percorso rimuove uno strato di crittografia, rivelando solo l'indirizzo del relay successivo.

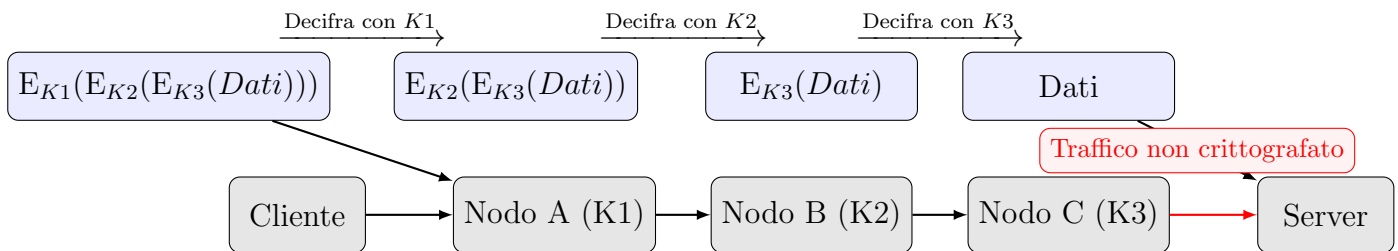


Figura 1: Principio del Routing a Cipolla (Tor).

Il diagramma (Fig. 1) illustra come il messaggio venga crittografato con le chiavi pubbliche di tutti i nodi in ordine inverso ($K3, K2, K1$) e decifrato sequenzialmente da ciascun nodo:

- **Nodo A** (Guardia) rimuove $K1$, conosce solo l'identità del Cliente e l'indirizzo del Nodo B.
- **Nodo B** (Relay Intermedio) rimuove $K2$, conosce solo l'indirizzo del Nodo A e l'indirizzo del Nodo C.
- **Nodo C** (Uscita) rimuove $K3$, conosce l'indirizzo del Nodo B e la **destinazione** (il Server). Non conosce l'identità del Cliente originale.

2 Confronto sui Livelli di Sicurezza, Privacy e Anonimato

La protezione dei dati e dell'identità di un utente dipende criticamente dalla combinazione di protocolli utilizzati. Di seguito, analizziamo i diversi scenari di connessione.

2.1 1. Connessioni Senza Crittografia (HTTP Normale)

Questo è lo scenario meno sicuro, tipico delle vecchie connessioni HTTP non protette da SSL/TLS.

- **Crittografia: Assente.**
- **Visibilità del Traffico:**
 - **Chiunque può vedere tutto:** Dati (password, messaggi), indirizzo IP del Cliente e contenuto della richiesta sono trasmessi in **chiaro**. Qualsiasi entità che monitori la rete (provider di servizi Internet, router, attaccanti) può leggere le informazioni.
- **Privacy e Sicurezza:** Estremamente basse. Non adatto per la trasmissione di informazioni sensibili.

2.2 2. Connessioni Crittografate (HTTPS Normale)

Questo è lo standard minimo di sicurezza per il web moderno, dove il protocollo HTTPS utilizza la crittografia TLS/SSL.

- **Crittografia: Crittografia End-to-End** tra Cliente e Host del sito (tramite chiave privata e pubblica del sito per stabilire la chiave simmetrica).
- **Visibilità del Traffico:**
 - **Contenuto Nascosto:** I dati (password, corpo dei messaggi) sono cifrati e visibili solo all'Host.
 - **Metadati Visibili:** Entità esterne (ISP, attaccanti) possono vedere l'indirizzo IP del Cliente e l'indirizzo IP del Server (il sito web che si sta visitando).
- **Privacy e Sicurezza:** Alta sicurezza sul contenuto, ma **l'identità e la posizione del Cliente non sono anonime**. L'Host del sito vede tutto (IP, dati decifrati) e può condividere tali informazioni.

2.3 3. Anonimato con Traffico Non Cifrato (TOR senza HTTPS)

Scenario in cui si usa la rete Tor per l'anonimato, ma si accede a un sito che utilizza solo HTTP.

- **Crittografia: Crittografia a strati** all'interno della rete Tor (tra Cliente e Relay adiacenti). **Assente** tra l'Ultimo Relay e il Server di destinazione.
- **Visibilità del Traffico:**
 - **All'interno di Tor:** La connessione è sicura grazie alla crittografia a cipolla.
 - **All'Uscita (Exit Node):** Dopo l'ultimo Relay (Exit Node), i dati viaggiano in **chiaro** verso il Server di destinazione. L'Exit Node può quindi vedere l'intero contenuto della comunicazione (se non è HTTPS).

- **Anonimato:**
 - **Località:** La posizione reale del Cliente è nota solo al **Primo Relay** (Guard Node).
 - **Attacco Vettoriale:** L'anonimato è a rischio. L'**Exit Node** può spiare l'intero contenuto della comunicazione. Gli **Intermediate Relay** non possono spiare il sito di destinazione.
- **Conclusione:** Sconsigliato. L'anonimato è garantito, ma non la riservatezza del contenuto.

2.4 4. Anonimato e Crittografia (TOR con HTTPS)

Questo scenario offre il massimo livello di protezione, combinando l'anonimato di Tor con la crittografia end-to-end di HTTPS.

- **Crittografia:**
 - **Tor:** Crittografia a cipolla tra Cliente e l'Exit Node.
 - **HTTPS:** Crittografia End-to-End tra l'Exit Node e l'Host del Sito.
- **Visibilità del Traffico:**
 - **Exit Node:** Il Relay di uscita **non può decifrare** il contenuto della comunicazione, in quanto è cifrato tramite HTTPS (visibile solo all'Host del sito). Vede solo che sta inoltrando traffico cifrato verso un indirizzo IP specifico.
 - **Host del Sito:** L'Host vede tutto il contenuto della comunicazione (una volta decifrato) e vede l'indirizzo IP dell'**Exit Node**.
- **Anonimato:**
 - **Località:** La posizione reale del Cliente è nota solo al Primo Relay.
 - **Riservatezza:** I dati sono visibili **solo** dall'Host (e da eventuali terze parti con cui l'Host condivide i dati).
- **Conclusione:** Massima sicurezza. Offre sia anonimato (nasconde l'IP reale) che riservatezza (nasconde il contenuto a tutti i Relay e intercettatori).

Sintesi dei Rischi

- Il livello di **Anonimato** è determinato principalmente da **Tor**.
- Il livello di **Riservatezza del Contenuto** è determinato principalmente da **HTTPS**.

3 Creazione di un Circuito Tor

Un circuito Tor è una catena di N relay (generalmente tre, R_1, R_2, R_3) stabilita tra il cliente e il server di destinazione.

3.1 Fasi di Creazione

1. **Selezione dei Relay:** Il cliente sceglie una catena di N router ($R_1 \dots R_n$) da una lista nota (Directory Nodes).
2. **Crittografia Asimmetrica Iniziale:** Il cliente conosce le **chiavi pubbliche** di tutti i relay selezionati.
3. **Creazione della Cipolla:** Il messaggio da inviare al Server è crittografato in strati, uno per ogni relay.
4. **Estensione del Circuito (Handshake):** la fase di handShake non ha come protagonista un unico messaggio ma uno per ogni router costruendo il percorso mano a mano (più sicuro che uno unico):
 - Il cliente invia un messaggio di **CREAZIONE** al primo router (R_1) crittografato con la chiave pubblica di R_1 . Questo stabilisce una chiave simmetrica temporanea (K_1) (il cliente la richiede ed entrambi la stabiliscono, quindi non serve rimandarla indietro, punto importante da capire, altrimenti quando R_2 rimanda indietro la sua chiave R_1 la saprebbe).
 - Per estendere il circuito a R_2 , il cliente crea un nuovo messaggio:
 $E_{K_1}(\text{Extend to } R_2, E_{K_{\text{pub}, R_2}}(\text{Key}))$.
 - R_1 decifra con K_1 , vede che deve estendere il circuito a R_2 . Inoltra il messaggio a R_2 il quale stabilisce la chiave simmetrica K_2 con *Client*.
 - Il processo si ripete per tutti i nodi, stabilendo una chiave simmetrica unica (K_m) tra il Cliente e ogni nodo R_m .

3.2 Fase di Comunicazione

- stabilita la connessione il client cifrerà il messaggio con tutte le chiavi simmetriche.
- Il server semplicemente invierà la risposta all'ultimo odo il quale cifrerà con la sua chiave simmetrica e invierà al nodo precedente e così via fino al client.

Tabella 1: Ruoli di Anonimato nel Circuito Tor a $N = 3$

Nodo	Conosce l'Identità del Cliente?	Conosce la Destinazione?
R_1 (Guardia)	Sì (Comunicazione diretta)	No (Conosce solo R_2)
R_2 (Intermedio)	No (Conosce solo R_1 e R_3)	No (Conosce solo R_1 e R_3)
R_n (Uscita/Last Relay)	No (Conosce solo R_{n-1})	Sì (Comunica con il Server)

4 Anonimato Bidirezionale: I Servizi Nascosti

Gli Onion Services (Servizi Nascosti) garantiscono l'anonimato bidirezionale, nascondendo sia la posizione del Cliente che quella del Server (Host). La comunicazione è stabilita tramite un punto di incontro segreto chiamato Rendezvous Point (RP).

4.1 Struttura e Ruoli dei Nodi Specializzati

- **Directory Nodes (HSDir):** (una sorta di **DNS**) Funzionano come un registro pubblico e distribuito in cui gli Host pubblicano i loro descriptor (ip degli **Introduction Point**, le loro **chiavi** pubbliche, inoltre la **firma** dell'host per verificare sia proprio lui).
- **Introduction Point (IP):** Nodi Tor scelti dall'Host per ricevere le richieste di connessione (end-point della connessione onion come per il client).
- **Rendezvous Point (RP):** Nodo Tor scelto dal Cliente che funge da ponte finale per l'incontro anonimo (l'endpoint del primo circuito Tor stabilito dal client).

4.2 Processo di Stabilimento della Connessione

Il processo si articola in due flussi paralleli (Host e Cliente) che convergono al Rendezvous Point.

4.3 Processo di Stabilimento della Connessione Onion Service

Il processo si articola in due flussi distinti ma paralleli (Host e Cliente) che convergono al Rendezvous Point (RP) per garantire l'anonimato bidirezionale.

- **A. Processo del Servizio Nascosto (Host)**

L'Host compie i seguenti passi per rendersi raggiungibile anonimamente:

1. **Selezione degli Introduction Points (IP):** L'Host (Server) sceglie casualmente N nodi Tor dalla lista dei Relay per fungere da Punti di Introduzione (**IP**).
2. **Costruzione Circuiti di Lunga Durata:** L'Host stabilisce un **circuito Tor anonimo di lunga durata** verso ciascun IP. L'IP funge da ultimo nodo di questo circuito e viene reso cieco rispetto all'IP reale dell'Host.

$$\text{Host} \xrightarrow{\text{Circuito Anonimo}} \text{IP}_m$$

3. **Pubblicazione del Descrittore:** L'Host crea un **Descrittore** (un documento di metadati) contenente:

- La **chiave pubblica** dell'Host (ricavata dall'indirizzo **.onion**).
- Gli **indirizzi** di tutti gli IP scelti.

Il Descrittore viene **firmato crittograficamente** dall'Host (con la sua chiave privata) per garantirne l'autenticità e l'integrità. Viene poi pubblicato sugli **HSDir** (Directory Nodes dedicati ai Servizi Nascosti).

- **B. Processo del Cliente**

Il Cliente compie i seguenti passi per localizzare e avviare l'incontro con l'Host:

1. **Recupero del Descrittore:** Il Cliente, conoscendo l'indirizzo `.onion`, interroga un **HSDir** per recuperare il Descrittore pubblicato dall'Host. Il Cliente **verifica la firma** per autenticare il Descrittore.
2. **Scelta e Circuito RP:** Il Cliente sceglie casualmente un nodo Tor per fungere da **Rendezvous Point (RP)** e stabilisce un proprio **circuito Tor anonimo** verso di esso.

Cliente $\xrightarrow{\text{Circuito Anonimo}}$ RP

3. **Richiesta di Introduzione:** Il Cliente seleziona uno degli IP dal Descrittore e invia una **Richiesta di Introduzione** attraverso il suo circuito Tor standard verso l'IP. La richiesta contiene due informazioni fondamentali:
 - L'indirizzo del **RP** (dove avverrà l'incontro).
 - Un **codice segreto monouso** (*One-Time Secret*) che verrà usato per confermare l'identità al RP.

Il Payload (RP e Secret) è **cifrato con la chiave pubblica dell'Host** in modo che solo l'Host possa leggerlo.

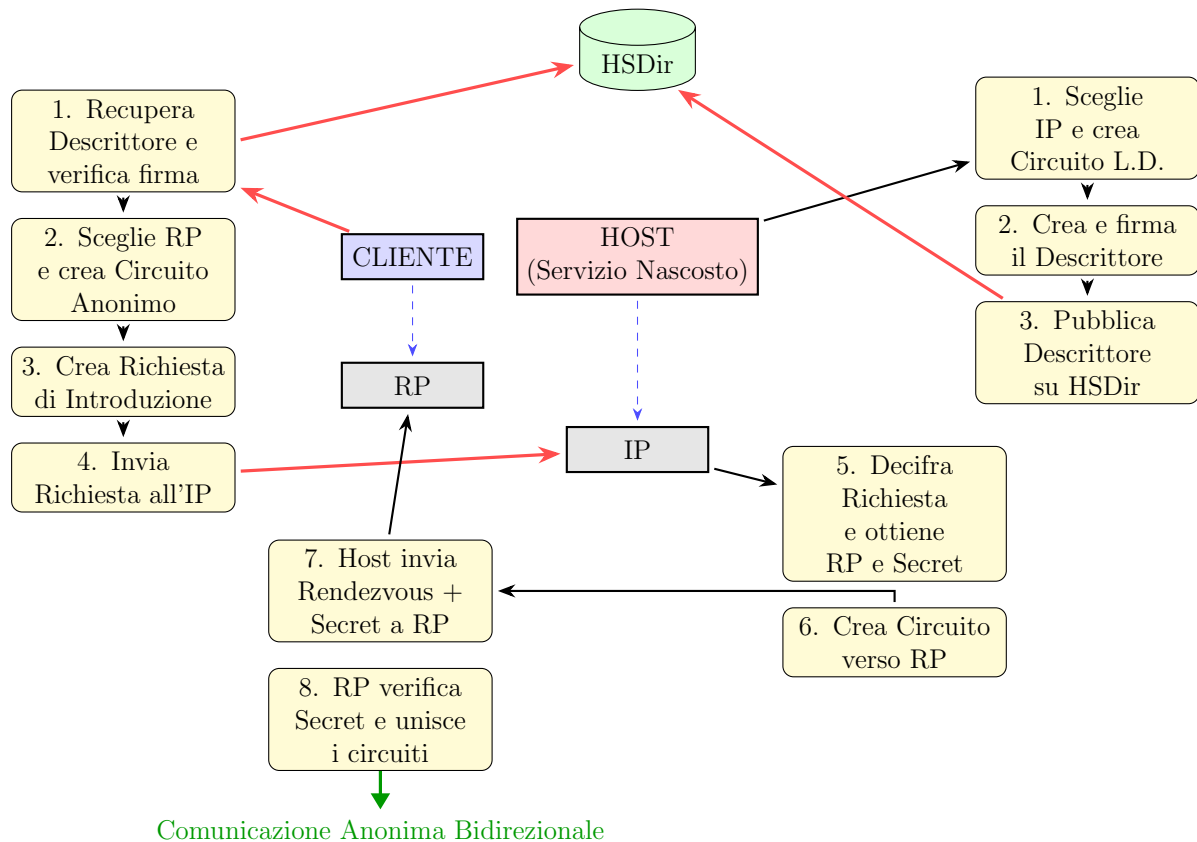
4.4 Rendezvous: L'Incontro Finale

4. **Connessione dell'Host al RP:** L'IP inoltra la richiesta di Introduzione (lunga il circuito di lunga durata) all'Host. L'Host decifra il messaggio, ne estrae l'indirizzo del RP e la One-Time Secret. Successivamente, l'Host stabilisce un **nuovo circuito Tor anonimo** che termina all'RP.

Host $\xrightarrow{\text{Circuito Anonimo}}$ RP

5. **Unione dei Circuiti:** L'Host invia un messaggio di Rendezvous al RP (inclusendo la One-Time Secret). Il RP verifica il codice segreto con quello fornito dal Cliente. Una volta confermato, il RP unisce i due circuiti anonimi.
6. **Comunicazione Bidirezionale:** La connessione è stabilita. Il traffico fluisce tra Cliente e Host (in entrambe le direzioni) attraverso il RP, garantendo l'anonimato completo ad entrambe le parti.

Schema dell'Iter per la Connessione ai Servizi Nascosti di Tor



5 Limiti e Svantaggi di Tor

Nonostante Tor offra un forte anonimato, presenta alcune limitazioni critiche:

- **Latenza e Velocità:** L'instradamento del traffico attraverso N relay (ognuno con operazioni di crittografia/decifratura) e la natura volontaria dei nodi causano una **significativa riduzione della velocità** e un aumento della latenza.
- **Banda (Bandwidth):** Ogni nodo Tor serve molteplici utenti contemporaneamente. I nodi, specialmente quelli gestiti da utenti privati, richiedono una **larga banda** e possono abbandonare il circuito in qualsiasi momento (se spengono i pc tutte le connessioni si interrompono).
- **Vulnerabilità all'Uscita (Exit Node):** Sebbene il traffico all'interno del circuito sia crittografato, il traffico tra il Nodo di Uscita (R_n) e il Server di destinazione è **NON crittografato** se il sito di destinazione non usa HTTPS. Il nodo di uscita può intercettare i dati in chiaro.
- **Attacchi di De-Anonimizzazione:** Tor non è immune agli attacchi che mirano a violare l'anonimato:
 - **Attacchi di Correlazione Temporale:** Se un attaccante controlla sia il nodo Guardia (R_1) che il nodo di Uscita (R_n), può correlare i tempi di entrata e uscita dei pacchetti per identificare il Cliente (Attacco End-to-End).

- **Sybil Attacks:** Un attaccante inietta molti nodi malevoli nella rete Tor per aumentare la probabilità di controllare l'intero circuito.
- **Requisiti Software:** L'utilizzo del browser Tor richiede spesso un'edizione personalizzata di Firefox per prevenire *fingerprinting* (i server possono memorizzare le info dell'hw del client o il suo fuso orario ecc per poi matchare queste info e riconoscerli anche se hai cambiato ip) e altre vulnerabilità basate sul browser.